

Activités : Le numérique et les droits fondamentaux des personnes

Activité :

La situation étudiée concerne la société Facebook : personne morale de nationalité américaine (Siège sociale à San Francisco) et Monsieur Leman, personne physique, résident européen. Monsieur Leman a demandé à la société Facebook de supprimer ses données personnelles et cela n'a pas été réalisé. Pour mieux comprendre la situation, on rappelle que la « Suppression » des données personnelles fait partie RGPD et donc Monsieur Leman peut invoquer ce droit. En effet, le RGPD protège les données personnelles de l'ensemble des résidents européens des traitements que peuvent en faire les personnes morales ou physiques.

Pour répondre à la première interrogation de Monsieur Leman, Facebook a l'obligation de répondre à la demande de Monsieur Leman et d'effacer ses données personnelles. Sinon, il peut s'adresser à la CNIL (Commission Nationale de l'Informatique et des Libertés) pour signaler le non-respect de ses droits.

Concernant la deuxième interrogation, Monsieur Leman se demande pourquoi le magasin de bricolage lui demande des informations personnelles, comme la composition de sa famille, sans information sur le document. Selon le RGPD, une entreprise doit toujours indiquer pourquoi elle collecte ces données et comment elles seront utilisées. Sachant que cette information manque, Monsieur Leman a plusieurs choix. Il peut demander au magasin pourquoi ces données sont demandées. Il peut aussi refuser de répondre si ces informations ne sont pas utiles pour la carte de fidélité. Il peut également le signaler à la CNIL.

Activité 1 :

La personne en charge doit vérifier si les données du client ont été collectées sur la base de son consentement. Si c'est le cas, et que le client retire son consentement, l'entreprise doit supprimer ses données comme indiqué dans le cours sur « le droit à l'effacement et autres droits ». De plus d'autres situations permettent d'obtenir l'effacement. Nous pouvons citer par exemple lorsque « les données sont utilisées à des fins de prospection » ou encore que « les données ne sont plus nécessaires au regard des objectifs pour lesquelles elles ont été initialement collectées ou traitées ».

Activité 2 :

L'article 17 du RGPD traite du droit à l'effacement. En effet, cet article permet aux personnes de demander la suppression de leurs données personnelles sous certaines conditions comme des données inutiles, un consentement retiré, un traitement illicite, etc.

Activité 3 :

Le droit à l'effacement permet de demander la suppression totale des données d'une base de données alors que le droit au déréférencement concerne uniquement les moteurs de recherche (ex : Google). Le droit à l'effacement peut par exemple être une entreprise qui doit supprimer mes données si je ne veux plus qu'elle les utilise. Pour le déréférencement, cela peut être de demander le retrait d'un lien contenant des informations personnelles des résultats de recherche. Cependant, l'information peut toujours exister sur le site d'origine.

Activité 4 :

Les autres droits des personnes concernant leurs données personnelles sont : Le droit d'accès qui est de demander quelles données une entreprise possède sur soi. Le droit de rectification qui est de corriger des informations erronées. Le droit d'opposition qui est de refuser que ses données soient utilisées (par exemple, pour de la publicité). Le droit à la limitation du traitement qui est d'exiger que l'entreprise conserve les données mais ne les utilise plus temporairement. Le droit à la portabilité qui est de récupérer ses données pour les transférer à un autre service. Et enfin le droit d'être informé qui est d'être informé sur la collecte et l'utilisation des données.

Activité :

Tout d'abord, la société CEAC doit informer les personnes sondées sur plusieurs points pour être conforme avec le RGPD. Elle doit leur expliquer qui collecte les données, pourquoi elles sont utilisées, combien de temps elles seront conservées et quels sont leurs droits. Elle doit aussi préciser si les données seront partagées avec d'autres entreprises ou non. Ces informations doivent être accessibles à tout le monde.

Ensuite, concernant ses sous-traitants, la société CEAC doit s'assurer qu'ils respectent aussi le RGPD. Elle doit se mettre d'accord avec eux et préciser comment ils doivent gérer les données et quelles mesures de sécurité appliquer. En effet, il est aussi important de vérifier que les sous-traitants protègent bien les données. La société CEAC peut tenir par exemple un « carnet de bord » des traitements de données pour prouver qu'elle respecte bien le RGPD.

Activité 1 : définir ce qu'est un risque élevé pour la vie privée.

Un risque élevé pour la vie privée est une situation dans laquelle le traitement de données personnelles peut engendrer des conséquences négatives pour les droits et libertés des personnes.

Activité 2 :

Selon le RGPD, les données de santé sont sensibles et nécessitent une protection renforcée. Prévenir les individus de la collecte et du traitement de leurs données est obligatoire mais cela n'est pas suffisant pour être en accord avec la réglementation. L'entreprise doit s'assurer que le traitement repose sur une base légale appropriée par exemple le consentement explicite des personnes concernées ou une nécessité médicale reconnue. Elle doit également prendre des mesures de sécurité strictes pour garantir la confidentialité et l'intégrité des données en empêchant tout accès non autorisés. Si le traitement comporte un risque élevé pour les droits et libertés des personnes une Analyse d'Impact sur la Protection des Données (AIPD) doit être faite avant sa mise en œuvre. En plus la durée de conservation des données doit être encadrée et limitée à ce qui est nécessaire avec une suppression ou une anonymisation au-delà de cette période. Enfin l'entreprise doit respecter les droits des individus par exemple le fait de leur permettre d'accéder à leurs données, de les rectifier, de demander leur effacement ou encore de s'opposer à leur traitements. Ainsi se contenter d'informer les individus ne suffit pas il est obligatoire de respecter l'ensemble des lois du RGPD pour garantir un traitement conforme et sécurisé des données de santé.

Activité finale :

1)

Les principaux points à l'origine de la décision contre Brico Privé sont que la CNIL a sanctionné Brico Privé pour plusieurs non-respects du RGPD. Tout d'abord, Brico Privé n'a pas défini ni respecté une durée pour la conservation des données personnelles proportionnée à leur finalité ce qui constitue un non-respect du principe de limitation de la conservation. Elle n'a pas non plus donné aux utilisateurs une information complète sur l'usage de leurs données comme à propos de la durée de conservation et les bases légales du traitement. Enfin elle n'a pas respecté l'obligation à l'effacement sur demande en ne supprimant pas les données des utilisateurs qui avait demandé la suppression de leur compte et qui se sont limités à désactiver ces comptes sans supprimer les informations personnelles associées.

2)

Nous allons citer d'autres exemples de sanctions prises par la CNIL à l'encontre de sociétés ne respectant pas le RGPD ainsi que les motifs de ces sanctions. On peut citer Amazon France Logistique en 2021 qui a été condamnée à 35 millions d'euros pour l'utilisation excessive de caméras de surveillance des employés mais également atteinte à leur vie privée. Nous avons également TikTok en 2023 qui a été condamnée à 5 millions d'euros pour défaut d'information des utilisateurs et absence d'option claire pour refuser les cookies. Il y a également Clearview AI en 2022 qui a été condamnée à 28 millions d'euros pour collecte et utilisation illégale de photos issues d'internet pour une base de reconnaissance faciale sans consentement.